Proyecto Final

Gestión de riesgos: Desarrollo de un SGSI

Isaac Daniel Monge Muñoz

José Pablo Picado Chaves

Carolina Jarquín González

Universidad CENFOTEC

Gestión de Riesgos

Profesor: Edgar Ricardo Zamora Gatgens

Fecha: Agosto, 2025

Índice

Índice **2**
Desarrollo **3**
Evaluación de contexto: 3
Activos críticos. 3
Procesos Clave. 3
Entorno Operativo. 4
Identificación de riesgos: 5
Evaluación y análisis de riesgos: 8
El Análisis de Impacto en el Negocio (BIA) 8
Evaluación de Impacto y Probabilidad 11
Matriz de Riesgo 13
Tratamiento de riesgos: 14
Plan de Acción. 14
Opciones para tratar los riesgos identificados. 16
Roles y Responsabilidades. 18
Monitoreo y revisión: 18

Desarrollo

Evaluación de contexto:

Es una empresa costarricense que se especializa en el desarrollo de software personalizado y la consultoría en tecnología, cuentan con un equipo de 30 empleados. Operando en sectores con regulaciones sumamente altas como lo son salud y finanzas, donde la confidencialidad, integridad y disponibilidad de la información son prioridad. Debido a los sectores tan exigentes en los que se encuentra se centra en ofrecer soluciones tecnológicas innovadoras y adaptadas para cada situación además de una fuerte y robusta seguridad para proteger los datos de los clientes y su reputación con los mismos.

Activos críticos.

- Código y software desarrollado: Propiedad intelectual que representa la base de sus servicios.
- Datos de clientes: Información sensible de los sectores que abarca además de estar sujeta a estrictas regulaciones bajo la ley.
- Infraestructura tecnológica: Servidores, bases de datos, estaciones de trabajo y las herramientas que se ven implicadas en los servicios que se brindan.
- Personal técnico: Los 30 empleados mencionados los cuales son esenciales para la continuidad y calidad operativa de los servicios que brindan.

Procesos Clave.

- Desarrollo de software personalizado: Diseño, codificación, prueba y entrega de software generado a medida para el sector y la necesidad del cliente.
- Consultoría tecnológica: Evaluación de necesidades del cliente, diseño de soluciones y soporte técnico.

- Gestión de datos de los clientes: Recolección, almacenamiento, procesamiento y protección de información sensible asegurando la confidencialidad e integridad de los clientes.

Entorno Operativo.

La empresa opera en un entorno sumamente competitivo y regulado, donde las amenazas cibernéticas como puede ser ransomware o phishing suceden con gran frecuencia y además de esto la empresa debe de cumplir con regulaciones como lo son la ley 8968 y de manera internacional en caso de trabajar con empresas internacionales deben de cumplir con las normativas GDPR y por supuesto debemos de considerar que al hablar de datos de clientes se toma en cuenta la reputación e integridad de la empresa. En esta área digital en la cual la empresa opera se exige una infraestructura robusta para manejar datos en la nube o en entornos híbridos mientras que la dependencia de terceros agrega riesgos en la cadena de suministro que se encuentran un poco fuera del control de la empresa, la implementación del SGSI busca mitigar estos riesgos agregados, fortalecer la confianza del cliente y mejorar aún más la reputación de InnovaTech.

Identificación de riesgos:

Para llevar a cabo la identificación de riesgos que puedan afectar la seguridad de la información en InnovaTech Solutions S.A., se aplicó un enfoque metodológico mixto que integra técnicas cualitativas, participación del personal y revisión documental, todo alineado con los lineamientos de la norma ISO/IEC 27005. El proceso comenzó con el análisis de escenarios, técnica que permitió simular situaciones hipotéticas como un ataque de ransomware, la pérdida de dispositivos con información sensible o una interrupción total del servicio por fallos eléctricos. Estos escenarios ayudaron a entender el impacto que tendrían distintos eventos disruptivos sobre los activos críticos. Luego, se llevaron a cabo entrevistas con el personal técnico, desarrolladores y personal administrativo, permitiendo obtener información directa sobre prácticas, debilidades y percepciones que no siempre están reflejadas en los documentos formales. Se complementa con la revisión de auditorías internas y registros de incidentes pasados, donde se analizaron patrones de fallos, debilidades en controles y vulnerabilidades no corregidas. Además, se utilizó una lista de verificación estructurada basada en los controles del Anexo A de la norma ISO/IEC 27001, lo cual permitió identificar riesgos asociados a procesos técnicos, factores humanos, infraestructura física y controles organizativos. Finalmente, se realizó un cruce entre los activos más importantes para la empresa como el personal técnico, la infraestructura tecnológica, los datos de clientes y el software desarrollado y las amenazas potenciales, logrando así construir un catálogo inicial de riesgos como base para su análisis posterior mediante el BIA y la matriz de evaluación.

El catálogo de riesgos identificados son los siguientes

Riesg	Descripción del Riesgo	Activo Afectado	Amenaza	Vulnerabilidad

o ID				
R1	Acceso no autorizado a datos de clientes debido a fallos en el control de accesos	Datos de clientes	Acceso no autorizado	Falta o falla en controles de acceso
R2	Pérdida de información sensible por robo o extravío de laptops fuera de la oficina	Laptops con datos sensibles	Robo o extravío	Uso de dispositivos fuera de control
R3	Interrupción total de servicios por fallas eléctricas que afectan infraestructura	Infraestructura tecnológica	Fallas eléctricas	Dependencia de suministro eléctrico sin respaldo
R4	Infección de sistemas críticos por malware a través de correos de phishing	Sistemas críticos de TI	Malware via phishing	Falta de filtros o capacitación
R5	Modificación maliciosa o no autorizada del código fuente en repositorios	Repositorios de código fuente	Acceso no autorizado / sabotaje	Control insuficiente de acceso y revisión
R6	Divulgación accidental de información confidencial por errores humanos	Información confidencial	Error humano	Falta de capacitación y procesos seguros

R7	Pérdida de datos por fallos o ausencia de copias de seguridad confiables	Datos críticos	Fallo de almacenamiento	Falta o falla de backups confiables
R8	Fuga de información mediante uso de dispositivos USB sin restricciones	Datos corporativos en PCs	Robo o fuga de información	Uso sin restricción de dispositivos USB
R9	Exposición de vulnerabilidades en aplicaciones web sin actualizaciones	Aplicaciones web	Vulnerabilidades explotadas	Falta de actualizaciones y pruebas
R10	Mantenimiento de accesos activos por exempleados que ya no pertenecen	Sistemas de acceso y datos	Accesos no autorizados	Falta de desactivación oportuna de cuentas

Estos riesgos fueron identificados con el objetivo de ser evaluados mediante el Análisis de Impacto al Negocio (BIA), que permitirá establecer el nivel de criticidad de cada activo, y posteriormente serán clasificados en una matriz de riesgos según su impacto y probabilidad. Este proceso es clave para definir el tratamiento adecuado de cada riesgo y asegurar la protección de la información dentro del SGSI.

Elegimos los riesgos R1, R4, R7, R5 y R10 porque son los que más afectan la seguridad y continuidad del negocio de InnovaTech. Son los más críticos por su alto impacto

y probabilidad, por eso los usamos en el BIA y luego en la matriz de riesgos para priorizar su gestión de manera efectiva.

Usamos primero el Análisis de Impacto en el Negocio (BIA) porque es el proceso que permite identificar y comprender cuáles son los procesos, funciones y activos más críticos para la continuidad operativa de la empresa, así como el nivel de impacto que tendría para el negocio la interrupción causada por cada riesgo identificado. El BIA ayuda a establecer claramente qué partes del negocio no pueden quedar detenidas y en qué medida, definiendo objetivos de recuperación (como el RTO) y recursos necesarios para garantizar la continuidad.

Una vez que hemos realizado el BIA y sabemos qué riesgos y procesos son críticos y cuál es su impacto potencial, aplicamos la matriz de riesgos para evaluar con detalle la probabilidad de ocurrencia y el impacto ya cuantificado, y así obtener un nivel de riesgo para cada amenaza. Esta matriz clasifica los riesgos en categorías (Muy Alto, Alto, Moderado, Bajo) mediante un cruce estructurado de probabilidad e impacto, facilitando la priorización visual y clara de los riesgos que requieren atención prioritaria y recursos inmediatos.

Evaluación y análisis de riesgos:

El Análisis de Impacto en el Negocio (BIA)

Proceso crítico: Control y acceso a datos de clientes (R1) Impacto de la interrupción: Acceso no autorizado a datos sensibles de clientes, pérdida de

confidencialidad, sanciones legales por incumplimiento normativo, daño reputacional severo y pérdida de confianza.

Objetivos de recuperación (RTO): RTO: 4 horas para minimizar exposición y cumplir normativas.

Recursos necesarios: Sistemas robustos de control de acceso (MFA), auditorías, revisiones periódicas de permisos, formación en gestión de accesos.

Proceso crítico: Defensa contra malware y phishing (R4)

Impacto de la interrupción: Infección de sistemas críticos que compromete integridad y disponibilidad, posible propagación de ransomware o brechas masivas de seguridad.

Objetivos de recuperación (RTO): RTO: 8 horas para mitigación y limpieza.

Recursos necesarios: Soluciones antimalware actualizadas, filtros de correo, capacitación continua, planes de respuesta a incidentes.

Proceso crítico: Pérdida de datos por fallos o ausencia de backups (R7)

Impacto de la interrupción: Pérdida definitiva de datos críticos que puede paralizar operaciones, causar pérdida financiera y dificultar la recuperación inmediata tras incidentes.

Objetivos de recuperación (RTO): RTO: 2 horas para restauración desde backups

confiables.

Recursos necesarios: Sistemas automatizados de backup, almacenamiento seguro (off-site), pruebas regulares de recuperación, documentación.

Proceso crítico: Modificación maliciosa o no autorizada del código fuente (R5)

Impacto de la interrupción: Introducción de vulnerabilidades o errores en productos finales, perdiendo confianza del cliente y exponiendo a futuros ataques o fallas.

Objetivos de recuperación (RTO): RTO: 12 horas para restaurar versión segura y asegurar repositorios.

Recursos necesarios: Control de versiones con acceso restringido, revisiones de código, autenticación fuerte en repositorios, políticas de cambios.

Proceso crítico: Mantenimiento de accesos activos de exempleados (R10)

Impacto de la interrupción: Accesos no revocados que permiten filtraciones, sabotajes o uso indebido de la información, afectando confidencialidad e integridad, además de incumplimiento normativo.

Objetivos de recuperación (RTO): RTO: 4 horas para revocar accesos y realizar auditoría.

Recursos necesarios: Sistemas de gestión de identidad y acceso (IAM), procesos formales de baja, auditorías regulares de cuentas, políticas claras.

Evaluación de Impacto y Probabilidad

Riesgo	**Descripción**	**Probabilidad (1-4)**	**Impacto (1-4)**	**Nivel de Riesgo (PxI)**	**Categoría**	**Vulnerabilidades Identificadas**
R1	Acceso no autorizado a datos de clientes debido a fallos	3 (Media-Alta)	4 (Muy Alto)	12	Alto	Controles de acceso débiles, falta de autenticación multifactor, permisos no revisados, monitoreo insuficiente.
R4	Infección por malware mediante phishing	4 (Alta)	4 (Muy Alto)	16	Muy Alto	Usuarios no capacitados, filtros de correo débiles, antimalware no actualizado, falta de respuesta rápida a incidentes.
R7	Pérdida de datos por fallos o ausencia de backups confiables	2 (Media-Baja)	4 (Muy Alto)	8	Moderado	Falta de automatización en backups, almacenamiento inseguro, ausencia de pruebas periódicas de recuperación.

R5	Modificación maliciosa o no autorizada del código fuente	2 (Media-Baja)	4 (Muy Alto)	8	Moderado	Control de versiones básico, acceso poco restringido a repositorios, falta de revisiones y auditorías frecuentes.
R10	Accesos activos no revocados de exempleados	3 (Media-Alta)	3 (Alto)	9	Alto	Procesos de baja difusos, sistemas IAM insuficientes, pocas auditorías de accesos y ausencia de revisiones periódicas.

Matriz de Riesgo

La matriz de riesgo muestra el nivel calculado con base en la probabilidad e impacto.

Colores: Muy Alto (13-16), Alto (9-12) , Moderado (5-8), Bajo (1-4).



R1: Tiene una probabilidad de 3 y un impacto de 4, dando un nivel de riesgo de 12, que corresponde a la casilla naranja siendo un riesgo Alto.

R4: Tiene una probabilidad de 4 y un impacto de 4, dando un nivel de riesgo de 16, que corresponde a la casilla roja siendo un riesgo Muy Alto.

R7: Tiene una probabilidad de 2 y un impacto de 4, dando un nivel de riesgo de 8, que corresponde a la casilla amarilla siendo un riesgo Moderado.

R5: Tiene una probabilidad de 2 y un impacto de 4, dando un nivel de riesgo de 8, que corresponde a la casilla amarilla siendo un riesgo Moderado.

R10: Tiene una probabilidad de 3 y un impacto de 3, dando un nivel de riesgo de 9, que corresponde a la casilla naranja siendo un riesgo Alto.

Tratamiento de riesgos:

Plan de Acción.

Riesgo	**Medida de control**	**Explicación**
R1	Autenticación multifactor (MFA).	La autenticación multifactor (MFA) añade una capa adicional de seguridad al requerir dos o más formas de verificación, reduciendo el riesgo de accesos no autorizados. Se implementara en sistemas que manejen datos sensibles como lo son las bases de datos y las plataformas o herramientas para el desarrollo de software.
R2	Cifrado de datos.	El cifrado de datos en las laptops protege la información sensible haciéndola inaccesible sin la clave de descifrado y esto resulta perfecto contra robos o extravíos, haciendo esto se reduce el riesgo de pérdida o filtración de datos.
R3	Sistemas de respaldo eléctrico.	Los UPS y generadores mantienen los sistemas críticos operativos durante cortes de energía asegurando la continuidad del servicio y la disponibilidad de datos esenciales.

R4	Capacitación a los empleados.	Las capacitaciones o talleres periódicos capacitan a los empleados para poder identificar correos phishing y así reducir el riesgo de que malware dañino ingrese al sistema de la empresa protegiendo la integridad de los sistemas y las bases datos.
R5	Implementar roles y logs para las herramientas de desarrollo de software.	Los roles de acceso quién puede modificar el código según su rol y mediante los logs podemos ver quien hizo los cambios en caso de que ya fueron hechos, mediante este control podemos evitar cambios no autorizados a los códigos fuentes o saber quien hizo el cambio.
R6	Implementar software DLP para controlar y proteger comunicaciones.	El software DLP monitorea la comunicación de las laptops bloqueando el envío de información confidencial debido a un error humano, esta técnica es clave para la confidencialidad.
R7	Copias de seguridad automatizadas.	Las copias de seguridad diarias aseguran que los datos puedan recuperarse tras una pérdida o un ataque. Esto es vital para la continuidad del trabajo y/o servicios y para mantener la confianza del cliente ya que minimiza el daño o impacto de fallos o ciberataques.
R8	Bloquear los puertos USB.	El bloque de USB mediante dispositivos físicos impide conectar dispositivos no autorizados lo cual previene la fuga o robo de datos mediante una memoria portátil u otras herramientas que puedan utilizar este puerto..
R9	Calendario de	El calendario de actualizaciones nos ayuda a mantener las

	actualizaciones y pentesting regular.	aplicaciones web con el último parche de protección para ciberataques ya conocidos y mediante el pentesting podemos identificar las vulnerabilidades antes de que sean explotadas.
R10	Automatizar la remoción de accesos y revisión periódica del mismo.	Automatizando la desactivación de accesos al finalizar la relación laboral del empleado interno o externo con el documento o la herramienta nos permite evitar accesos indebidos y al revisarlo periódicamente nos aseguramos que los empleados inactivos no cuenten con ningún acceso en caso de fallas en la automatización.

Opciones para tratar los riesgos identificados.

Riesgo	**Opción de tratamiento**	**Justificación**
R1: Acceso no autorizado a datos de clientes.	Mitigación	Implementar MFA reduce accesos no autorizados al requerir múltiples verificaciones.
R2:Pérdida de información sensible por robo/extravío de laptops fuera de la oficina.	Mitigación	El cifrado de los datos los protegerá en caso de pérdida.
R3: Interrupción de servicios	Mitigación	UPS y generadores garantizan continuidad

por fallas eléctricas que afectan la infraestructura.		operativa, apoyando la disponibilidad de datos
R4: Infección de sistemas críticos por malware a través de correos de phishing	Mitigación	Capacitación y filtros anti-phishing previenen ataques, alineándose con el Artículo 5 de la Ley 8968 para proteger datos.
R5: Modificación maliciosa o no autorizada del código fuente en repositorios	Mitigación	Controles de acceso y auditorías protegen la integridad del código, un activo crítico.
R6: Divulgación accidental de información confidencial por errores humanos	Preventivo	Este software monitorea los correos y mensajes para así poder evitar que información sea enviada a destinatarios no autorizados.
R7: Pérdida de datos por fallos o ausencia de copias de seguridad confiables	Mitigación	Backups y pruebas aseguran recuperación.
R8: Fuga de información mediante uso de dispositivos USB sin restricciones	Mitigación	Políticas y controles físicos previenen transferencias no autorizadas.
R9: Exposición de vulnerabilidades en aplicaciones web sin actualizaciones	Mitigación	Las actualizaciones y pentesting cierran brechas, protegiendo datos accesibles vía web.

R10: Mantenimiento de accesos activos por ex empleados que ya no pertenecen	Mitigación	Procesos para dar de baja a exempleados y revisiones aseguran acceso mínimo a los datos sensibles

Roles y Responsabilidades.

Gerente de TI y Ciberseguridad: Unifica las funciones de TI y seguridad para una supervisión técnica integral, alineando medidas técnicas y administrativas.

Gerente de desarrollo: Protege los activos más valiosos de la empresa (como el código fuente) y garantiza que las aplicaciones cumplan con estándares de seguridad.

Gerente de RRHH: Combina funciones operativas y de recursos humanos para gestionar eficientemente la infraestructura y el personal, asegurando continuidad y cumplimiento.

Monitoreo y revisión:

Nivel	**Frecuencia**	**Responsable**	**Evidencia**
Logs / alertas SIEM	Continuo (24×7)	Equipo TI / Equipo de Seguridad	Logs y alertas automáticas

Escaneo de vulnerabilidades	Mensual	TI / Gestión de vulnerabilidad	Informe mensual (vulnerabilidad pendiente)
Revisión KPI	Mensual	Coordinador SGSI	Informe KPI con tendencias
Avances del plan de tratamiento	Trimestral	Gestor de Riesgos	Acta, % cumpliendo plazos
Auditoría interna	Anual	Auditor SGSI (interno o externo)	Informe con hallazgos
Reunión de revisión por dirección	Cada 6–12 meses (o tras auditoría)	Alta Dirección (CISO, CTO, CFO, Líder SGSI)	Minuta formal con decisiones